

Faculty of Business and Information Technology  
MITS 5600G: Security Policies and Risk Management  
Final Group Project – Security Policy

## Contents

|                                   |          |
|-----------------------------------|----------|
| <b>Academic Integrity .....</b>   | <b>1</b> |
| <b>Project Description .....</b>  | <b>1</b> |
| <b>Project Requirements .....</b> | <b>1</b> |
| <b>Project Deliverables .....</b> | <b>3</b> |
| <b>Grading Rubric.....</b>        | <b>4</b> |
| <b>List of Technologies.....</b>  | <b>4</b> |
| <b>Naming Convention.....</b>     | <b>8</b> |
| <b>Turnitin Usage .....</b>       | <b>8</b> |

## Academic Integrity

The sharing or uploading of course material, assignments, sample solutions, or tests to online platforms is strictly prohibited and constitutes a breach of academic integrity.

## Project Description

This group project focuses on developing a comprehensive set of policies for a technology of interest. Each group will analyze the chosen technology's security implications, operational risks, and business impact, and then create a set of professional security policies tailored to a specific organization.

Projects are completed in groups of two. If course enrollment increases significantly, the instructor may assign an additional member to an existing group.

Students who do not form a group by the end of Lecture 4 will be assigned to a group and topic by the instructor.

## Project Requirements

Your group is expected to complete the following:

### 1- Choose a Technology

Select one technology topic from the approved list provided below.

## 2- Write a Technology Summary

Prepare a 2–3 page summary discussing:

- The technology and how it works.
- Security risks, threats, vulnerabilities, and security benefits.
- Privacy, legal, ethical, regulatory, or compliance concerns.
- Potential business impact and operational considerations.
- Real-world usage examples, cybersecurity incidents, breaches, or case studies where applicable.

Your summary must reference at least five credible academic or industry sources.

Examples of acceptable sources include:

- Peer-reviewed journal articles
- Industry whitepapers
- Government publications
- Security standards and frameworks
- Vendor technical documentation
- Reputable cybersecurity reports

All references must be cited using APA format.

## 3- Choose an Organization

Choose a type of organization (e.g., healthcare, financial, educational, retail, manufacturing, government, etc.).

Your group should create a fictional organization appropriate for the selected industry sector. Examples:

- A fictional hospital
- A fictional bank
- A fictional manufacturing company
- A fictional retail organization

Policies must be tailored to the selected fictional organization and technology.

You may reference publicly available industry standards, frameworks, regulations, or documented practices where appropriate. However, do not reproduce, speculate about, or claim to represent the actual internal security policies or practices of a real-world organization unless explicitly cited and referenced.

The goal of this project is to design realistic and professional security policies, not to replicate the internal security practices of an actual organization.

#### 4- Develop Security Policies

Develop **four** standalone security policies related to the selected technology. Each policy must:

- Be written using the **singular policy format** discussed in class.
- Be approximately two pages in length.
- Include all major policy elements discussed during Week 2.
- Be tailored to the selected organization and technology.

Examples of policy areas may include:

- Acceptable use
- Access control
- Data protection
- Monitoring and logging
- Incident response
- Vendor management
- Remote access
- AI usage restrictions
- Mobile device management
- Privacy and retention

#### 5- Policy Format Requirement

Each policy must be written as a complete standalone policy document. Policies should include all policy document components we learned in class.

## Project Deliverables

### Final Project Report

The final report must be approximately 15-17 single-spaced pages long (including Cover Page, Table of Contents page, and References page).

Your report should include:

- Cover Page.
- Linkable Table of Contents.
- Technology Summary (2-3 pages).
- Set of Policies. Each policy consists of a 1-page policy introduction (scope, purpose, definitions) and a 2-page policy document (rules, responsibilities, compliance), for a total of 3 pages per policy.

- References Page.

## Grading Rubric

Your project will be graded on its clarity, coverage of security issues, and the policy's fit to the chosen business and technology:

| Criteria                                                                                                 | Marks |
|----------------------------------------------------------------------------------------------------------|-------|
| Quality of the technology summary: depth, relevance and analysis.                                        | 20    |
| Quality of the policies: completeness, practicality, and alignment with the technology and organization. | 50    |
| Clarity and organization of the report.                                                                  | 20    |
| Professionalism: writing quality, formatting consistency, APA citations, logical flow, and presentation  | 10    |

## List of Technologies

Choose one of the following topics for your project, and enroll in the corresponding Canvas group with the same number.

Note that the policy area examples listed below are **suggestions only**. Your group may develop different policy areas that better fit your chosen fictional organization and its specific risks. The examples are provided to help guide your thinking, not to restrict your creativity.

| Group # | Topic                                                                                                                                                                                                                                                                            |
|---------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1       | Biometric authentication (fingerprint scanners) for physical access control<br>Policy area examples: Biometric data consent and retention, Alternative access methods (card/pin backup), Template storage security (no raw fingerprints stored), Audit logging and access review |
| 2       | Smart building energy management systems (HVAC, lighting)<br>Policy area examples: Access control to HVAC interfaces, Data retention (occupancy patterns), Incident response (building lock/fire), Vendor remote access                                                          |

|    |                                                                                                                                                                                                                                                                            |
|----|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 3  | Corporate social media account management and employee brand advocacy<br>Examples of policy areas: Account ownership, approval workflow, brand impersonation response, employee termination process                                                                        |
| 4  | Use of email encryption and digital signatures for sensitive communications<br>Policy area examples: Mandatory encryption triggers, Key management and certificate lifecycle, Exception process, Auditing and non-repudiation logging                                      |
| 5  | Privacy-enhancing technologies (e.g., Tor, VPNs) on corporate networks<br>Policy area examples: Approved VPN vendors, prohibited uses (Tor for illicit activity), violation reporting and enforcement, restricted-use approval process                                     |
| 6  | Speech-to-text transcription tools in healthcare or legal workplaces<br>Policy area examples: Data retention and deletion, Patient/attorney confidentiality safeguards, Quality assurance and transcript verification controls, Third-party vendor security assessment     |
| 7  | Personal wearable devices (smart watches, fitness trackers, smart glasses, or any wearable with camera, microphone, GPS) in secure facilities<br>Policy area examples: Prohibited areas, Wireless transmission restriction, Incident reporting, Enforcement and violations |
| 8  | Use of external SaaS applications (e.g., Salesforce, Microsoft 365)<br>Policy area examples: SaaS approval and onboarding workflow, Data classification allowed per SaaS tier, Vendor security assessment (SOC2, ISO 27001), Offboarding data retrieval and deletion       |
| 9  | Internal Single Sign-On (SSO) and Identity and Access Management (IAM) systems<br>Policy area examples: Access request and approval workflow, Periodic access recertification, Privileged account monitoring, Emergency access procedure (break-glass)                     |
| 10 | Near Field Communication (NFC) systems for physical access and payments<br>Policy area examples: Cardholder data protection, physical card security, transaction logging, lost card revocation                                                                             |
| 11 | Public Wi-Fi hotspot services for customers (e.g., coffee shops, airports, hotels)<br>Policy area examples: Acceptable use (customers), Logging and monitoring, Content filtering, Legal disclaimer/terms of service                                                       |
| 12 | IoT medical devices (e.g., insulin pumps, patient monitors) in healthcare environments                                                                                                                                                                                     |

|    |                                                                                                                                                                                                                                                                                                                                                                                       |
|----|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|    | Policy area examples: Device inventory, firmware patching, network segmentation, incident response (device compromise)                                                                                                                                                                                                                                                                |
| 13 | AI-based fraud detection systems in e-commerce or financial platforms<br>Policy area examples: Model explainability, false positive handling, data retention for audits, vendor model validation                                                                                                                                                                                      |
| 14 | Customer-facing AI chatbots handling personal or payment information<br>Policy area examples: Data minimization, consent collection, chatbot disclosure (AI not human), breach notification                                                                                                                                                                                           |
| 15 | Commercial drone operations and aerial surveillance/data collection systems<br>Examples of policy areas: Data collection and retention, airspace compliance, device security and firmware updates, privacy notice (surveillance laws)                                                                                                                                                 |
| 16 | Digital twin systems for industrial control environments (e.g., factories, utilities, or power systems)<br>Examples of policy areas: Remote access and vendor maintenance controls, Real-time sensor data integrity and tampering detection, Network segmentation between OT and IT environments, Incident response and failover procedures for digital twin synchronization failures |
| 17 | Autonomous vehicle telematics and fleet passenger safety systems<br>Examples of policy areas: Data ownership (driver vs. fleet), accident data retention, privacy notice, third-party telematics vendor assessment                                                                                                                                                                    |
| 18 | Phishing simulation and employee security awareness training platforms<br>Examples of policy areas: Simulation approval process, employee notification (advance disclosure or no-notice policy), data handling (who clicked), remediation tracking                                                                                                                                    |
| 19 | Iris recognition systems for high-security area access<br>Examples of policy areas: Biometric consent, template storage security, performance standards (false acceptance/rejection rates), audit logging                                                                                                                                                                             |
| 20 | Facial recognition systems for employee attendance and building entry<br>Examples of policy areas: Consent requirement, alternative attendance methods, retention period, manager access restrictions                                                                                                                                                                                 |
| 21 | Bring Your Own Device (BYOD) programs in financial or enterprise environments                                                                                                                                                                                                                                                                                                         |

|    |                                                                                                                                                                                                                                                                    |
|----|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|    | Examples of policy areas: Approved devices, corporate data separation (containerization), remote wipe authority, employee privacy notice                                                                                                                           |
| 22 | Remote desktop and remote administration tools used by IT support teams<br>Examples of policy areas: Session logging, multifactor authentication, privilege elevation, vendor selection criteria                                                                   |
| 23 | Cloud-based file storage and collaboration platforms (e.g., Google Drive, OneDrive)<br>Examples of policy areas: Data classification allowed, sharing with external users, retention and deletion, legal hold process                                              |
| 24 | Voice assistants (e.g., Alexa for Business, Google Assistant) in workplace environments<br>Examples of policy areas: Controls on always-listening functionality, data retention of transcripts, microphone activation controls, facility restrictions (boardrooms) |
| 25 | Employee location tracking through corporate laptops, mobile devices, or badges<br>Policy area examples: Consent policy, Data minimization, Retention and deletion, Manager access controls                                                                        |
| 26 | Use of external USB drives and removable media in government or enterprise environments<br>Examples of policy areas: Encryption requirement, approval for use, scanning before access, loss reporting                                                              |
| 27 | Source code repositories and DevOps platforms (e.g., GitHub, GitLab, Bitbucket)<br>Examples of policy areas: Branch protection rules, access review frequency, secret scanning, fork/external collaboration policy                                                 |
| 28 | Video conferencing and virtual meeting platforms for executive or board communications<br>Policy area examples: Encryption standards, Recording and storage, Third-party vendor assessment, Executive meeting confidentiality controls                             |
| 29 | Automated patch management and endpoint update deployment systems                                                                                                                                                                                                  |

|    |                                                                                                                                                                                                                  |
|----|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|    | Policy area examples: Patching windows, critical patch SLA, exception process, rollback procedure                                                                                                                |
| 30 | Third-party customer support platforms and outsourced support data access<br>Examples of policy areas: Data access logging, support agent background checks, data localization, contract termination data return |
| 31 | Employee productivity and activity monitoring systems in remote or hybrid workplaces<br>Examples of policy areas: Notice to employees, data collected types, manager access limits, retention period             |

## Naming Convention

The submitted report must follow the naming convention: **FinalProject-GroupNumber.pdf**

**Example:** FinalProject-Group1.pdf

## Turnitin Usage

Turnitin will be used to ensure academic integrity.

Attempts to bypass Turnitin detection mechanisms, including but not limited to:

- Submitting images of text
- Using hidden characters
- Manipulating formatting
- Submitting AI-generated content without authorization
- Using paraphrasing tools to disguise copied material

may result in a grade of zero and may constitute a violation of academic integrity policies.

Students are responsible for ensuring that all submitted work complies with university academic integrity requirements.